

VULNERABILITY ANALYSIS

Wan Ahmad Naqeeb Bin Wan Mohd Nazmi

Lab 1

Objective:

Students learn how vulnerabilities are identified, classified, and prioritised, not exploited.

Scan with Nmap

- Access metasploitable 2 with the provided credentials (User and Password = msfadmin)
- Enter ifconfig to find the IP address (192.168.0.31)
- Scan! scan using Nmap -sV command. It list the version of the services

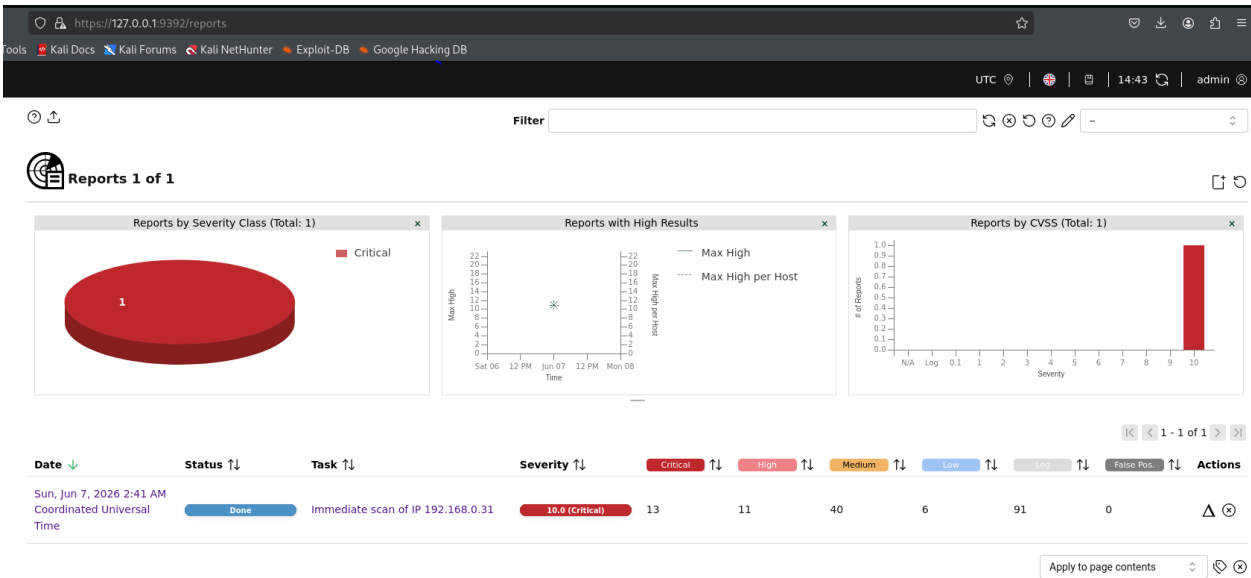
```
root@kali: ~/Desktop
Session Actions Edit View Help
zsh: suspended ping 192.168.0.31

(root@kali)~[~/Desktop]
# nmap -sV 192.168.0.31
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-06 23:55 +08
Nmap scan report for 192.168.0.31
Host is up (0.00025s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:E9:8B:8A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.59 seconds
```

Vulnerability Scan

- Scanned using OpenVAS



- Critical: 13
- High: 11
- Medium: 40
- Low: 6
- Log: 91

Top 5 Vulnerabilities

CVE	NVT	Hosts	Occurrences	Severity
CVE-1999-0618	The rexec service is running	1	1	10.0 (Critical)
CVE-2008-5304 CVE-2008-5305	TWiki < 4.2.4 Multiple XSS / Command Execution Vulnerabilities	1	1	10.0 (Critical)
CVE-2020-1938	Apache Tomcat AJP RCE Vulnerability (Ghostcat) - Active Check	1	1	9.8 (Critical)
CVE-2011-2523	vsftpd Compromised Source Packages Backdoor Vulnerability - Active Check	1	2	9.8 (Critical)
CVE-2001-0645 CVE-2002-1809 CVE-2004-1532 CVE-2004-2357 CVE-2006-1451 CVE-2007-2554 CVE-2007-6081 CVE-2009-0919 CVE-2014-3419 CVE-2015-4669 CVE-2016-6531 CVE-2018-15719 CVE-2024-22901	MySQL / MariaDB Default Credentials (MySQL Protocol)	1	1	9.8 (Critical)
CVE-2004-2687	DistCC RCE Vulnerability (CVE-2004-2687)	1	1	9.3 (Critical)

Vulnerability (NVT)	Explicit CVE ID(s)	CVSS Score & Severity
The rexec service is running	CVE-1999-0618	10.0 (Critical)
TWiki < 4.2.4 Multiple XSS / Command Execution Vulnerabilities	CVE-2008-5304, CVE-2008-5305	10.0 (Critical)
Apache Tomcat AJP RCE Vulnerability (Ghostcat) - Active Check	CVE-2020-1938	9.8 (Critical)
vsftpd Compromised Source Packages Backdoor Vulnerability - Active Check	CVE-2011-2523	9.8 (Critical)
MySQL / MariaDB Default Credentials (MySQL Protocol)	CVE-2001-0645, CVE-2002-1809, CVE-2004-1532, CVE-2004-2357, CVE-2006-1451, CVE-2007-2554, CVE-2007-6081, CVE-2009-0919, CVE-2014-3419, CVE-2015-4669, CVE-2016-6531, CVE-2018-15719, CVE-2024-22901	9.8 (Critical)

OpenVAS Scan Report

<https://github.com/Wan768/Week-10-Lab-1-4---MSploitable-2/blob/main/OpenVAS%20Report%20-%20Metasploitable%202.pdf>

Lab 2

1. The rexec service is running (CVE-1999-0618)
 - **CVSS Base Score:** 10.0 (CVSS v2) AV:N/AC:L/Au:N/C:C/I:C/A:C
 - **Attack Vector:** Network
 - **Privileges Required:** None (Authentication is bypassed or trivial)
 - **CWE Mapping:** CWE-16 (Configuration) or CWE-287 (Improper Authentication).
2. TWiki < 4.2.4 Multiple XSS / Command Execution (CVE-2008-5304, CVE-2008-5305)
 - **CVSS Base Score:**
 - 10.0 (CVSS v2 for CVE-2008-5305 RCE) AV:N/AC:M/Au:N/C:N/I:P/A:N
 - 4.3 (for CVE-2008-5304 XSS) AV:N/AC:L/Au:N/C:C/I:C/A:C
 - **Attack Vector:** Network
 - **Privileges Required:** None
 - **CWE Mapping:** CWE-78 (OS Command Injection) & CWE-79 (Cross-Site Scripting).
3. Apache Tomcat AJP RCE Vulnerability - Ghostcat (CVE-2020-1938)
 - **CVSS Base Score:** 9.8 (CVSS v3.1)
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
 - **Attack Vector:** Network
 - **Privileges Required:** None
 - **CWE Mapping:** CWE-22 (Improper Limitation of a Pathname to a Restricted Directory / Path Traversal).
4. vsftpd Compromised Source Packages Backdoor (CVE-2011-2523)
 - **CVSS Base Score:** 9.8 (CVSS v3.1) / 10.0 (CVSS v2)
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
 - **Attack Vector:** Network
 - **Privileges Required:** None
 - **CWE Mapping:** CWE-506 (Embedded Malicious Code).
5. MySQL / MariaDB Default Credentials (Multiple, e.g., CVE-2001-0645)
 - **CVSS Base Score:** 9.8 (Critical) AV:N/AC:L/Au:N/C:P/I:P/A:P
 - **Attack Vector:** Network
 - **Privileges Required:** None (The exploit is the act of logging in with known credentials).
 - **CWE Mapping:** CWE-1188 (Insecure Default Initialization of Resource) or CWE-521 (Weak Password Requirements).

Lab 3

1. The rexec service is running (CVE-1999-0618)

- Use Nmap to check if port 512 is open and running the rexec service

```
(root@kali)-[~]
# nmap -sV -p 512 192.168.0.31
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-07 14:41 +08
Nmap scan report for 192.168.0.31
Host is up (0.00016s latency).

PORT      STATE SERVICE VERSION
512/tcp   open  exec    netkit-rsh rexecd
MAC Address: 08:00:27:E9:8B:8A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.33 seconds
```

- **Decision:** True Positive
- **Technical Justification:** The manual service scan confirms that the remote execution daemon (rexec) is actively listening on port 512.

2. TWiki < 4.2.4 Multiple Vulnerabilities (CVE-2008-5304, CVE-2008-5305)

- Check the version or path via your web browser by navigating to the TWiki directory.

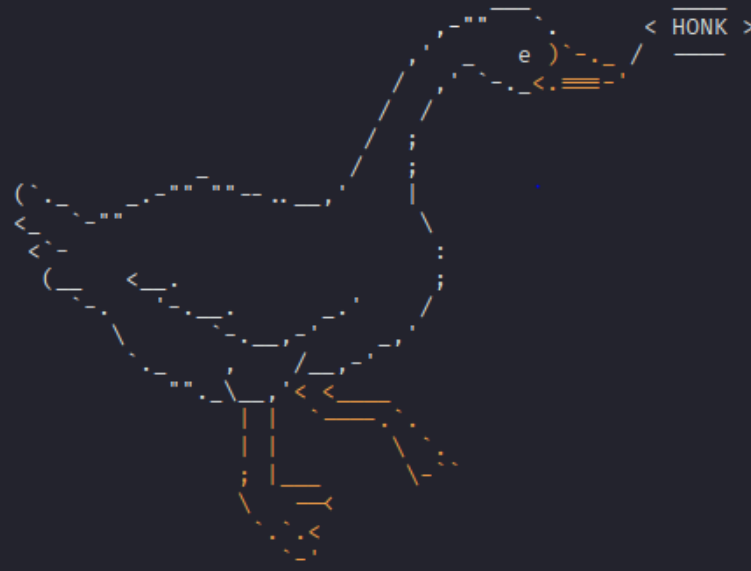
Topic **WelcomeGuest** . { [Edit](#) | [Attach](#) | [Ref-By](#) | [Printable](#) | [Diffs](#) | r1.20 | [>](#) | [r1.19](#) | [>](#) | [r1.18](#) | [More](#)
Revision r1.20 - 18 Jan 2003 - 09:53 GMT - [PeterThoeny](#)

- **Decision:** True Positive
- **Technical Justification:** Manual validation was performed via web browser by navigating to the TWiki application directory. Inspection of the page footer revealed a system page revision date of January 2003. This confirms the installed TWiki version is significantly older than the patched version 4.2.4

3. Apache Tomcat AJP RCE - Ghostcat (CVE-2020-1938)

- Since we're using kali, its best that we used metasploit console

```
(root@kali)-[~]
# msfconsole
Metasploit tip: After running db_nmap, be sure to check out the result
of hosts and services



      =[ metasploit v6.4.84-dev                                     ]
+ -- --=[ 2,547 exploits - 1,309 auxiliary - 1,680 payloads       ]
+ -- --=[ 431 post - 49 encoders - 13 nops - 9 evasion           ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

^[[B^[[B^[[B^[[A^[[A^[[A^[[A^[[A^[[Amsf > use auxiliary/admin/http/tomcat_ghostcat
msf auxiliary(admin/http/tomcat_ghostcat) > set RHOST 192.168.0.31
RHOST => 192.168.0.31
msf auxiliary(admin/http/tomcat_ghostcat) > set RPORT 8009
RPORT => 8009
```

```

REPORT => 8009
msf auxiliary(admin/http/tomcat_ghostcat) > run
[*] Running module against 192.168.0.31
<?xml version="1.0" encoding="ISO-8859-1"?>
<!--
Licensed to the Apache Software Foundation (ASF) under one or more
contributor license agreements. See the NOTICE file distributed with
this work for additional information regarding copyright ownership.
The ASF licenses this file to You under the Apache License, Version 2.0
(the "License"); you may not use this file except in compliance with
the License. You may obtain a copy of the License at

    http://www.apache.org/licenses/LICENSE-2.0

Unless required by applicable law or agreed to in writing, software
distributed under the license is distributed on an "AS IS" BASIS,
WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
See the License for the specific language governing permissions and
limitations under the License.
-->

<web-app xmlns="http://java.sun.com/xml/ns/j2ee"
  xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
  xsi:schemaLocation="http://java.sun.com/xml/ns/j2ee http://java.sun.com/xml/ns/j2ee/web-app_2_4.xsd"
  version="2.4">

  <display-name>Welcome to Tomcat</display-name>
  <description>
    Welcome to Tomcat
  </description>

  <!-- JSPC servlet mappings start -->

  <servlet>
    <servlet-name>org.apache.jsp.index_jsp</servlet-name>
    <servlet-class>org.apache.jsp.index_jsp</servlet-class>
  </servlet>

  <servlet-mapping>
    <servlet-name>org.apache.jsp.index_jsp</servlet-name>
    <url-pattern>/index.jsp</url-pattern>
  </servlet-mapping>

  <!-- JSPC servlet mappings end -->

</web-app>
[+] 192.168.0.31:8009 - File contents save to: /root/.msf4/loot/20260607150723_default_192.168.0.31_WEBINFweb.xml_6856
13.txt
[*] Auxiliary module execution completed
msf auxiliary(admin/http/tomcat_ghostcat) >

```

Decision: True Positive

Technical Justification: Manual validation using the Metasploit Framework's tomcat_ghostcat auxiliary module successfully exploited the misconfigured AJP connector on port 8009.

4. vsftpd Compromised Source Packages Backdoor (CVE-2011-2523)

- Grab the service banner from the FTP port using Netcat or Nmap to verify the version.

```

(root@kali)-[~]
# nc -nv 192.168.0.31 21
(UNKNOWN) [192.168.0.31] 21 (ftp) open
220 (vsFTPd 2.3.4)

```

- **Decision:** True Positive.
- **Technical Justification:** The banner grab directly returns vsftpd 2.3.4. This exact version contains a famous malicious backdoor inserted into its source code distribution.

5. MySQL / MariaDB Default Credentials (Multiple CVEs)

- Attempt a direct connection to the MySQL port (3306) using the root username and an empty password string.

```
(root@kali)-[~]  
# mysql -h 192.168.0.31 -u root --skip-ssl  
Welcome to the MariaDB monitor.  Commands end with ; or \g.  
Your MySQL connection id is 1439  
Server version: 5.0.51a-3ubuntu5 (Ubuntu)  
  
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.  
  
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.  
  
MySQL [(none)]> █
```

Decision: True Positive

Technical Justification: The connection attempt succeeds without requesting a password, granting administrative access to the database management system.

Lab 4

1. Vulnerability Ranking

Rank	Vulnerability	Exploit	Impact	Exposure
1	vsftpd Compromised Source Packages Backdoor	Requires no advanced tools. Anonymous ftp login works	Grants immediate access to root-level shell	High
2	TWiki RCE	Can be exploited via a simple web browser request or curl command	Grants command execution	High
3	MySQL Default Credentials	Requires no password to access MySQL	Complete control over all databases.	Medium
4	Tomcat Ghostcat (AJP)	Requires specific exploit scripts and understanding of the AJP protocol.	Allows reading of sensitive configuration files.	Medium
5	Rexec Services	Sends credentials in cleartext by Man-in-the-middle attack	Allows execution of arbitrary commands if credentials are obtained.	Low

2. Remediation List

- a. Stop or change vsftpd services
 - Kill the service, update to a clean version (like 3.0+), or switch to a secure alternative like SFTP.
- b. Secure MySQL
 - Run mysql_secure_installation, set a strong root password, and disable remote root logins.
- c. Patch TWiki
 - Upgrade TWiki to a patched version.
- d. Patch Tomcat
 - update the Tomcat software, disable the AJP connector if it's not being used
- e. Stop rexec protocols
 - Rexec services should be completely disabled and uninstalled from the operating system, and their ports blocked at the host firewall.

Why Can a Medium CVSS Can Be More Dangerous Than a High CVSS?

- A medium CVSS score can be more dangerous than a high one because CVSS only measures theoretical technical severity, not real-world risk. Attackers frequently weaponize lower-scored bugs as stepping stones for reachability, context, or exploit chains.